LIVRABLE — JOUR 3

Hardening Windows Server 2025

& Scripting Bash d'automatisation

Graulich Evan

HASSAM Delnah

TP de sécurité système — Windows Active Directory et Linux

Volet 1 — Hardening Windows Server 2025

Objectif : renforcer la sécurité d'un domaine Active Directory en appliquant des GPO, en détectant les comptes inactifs, et en limitant les protocoles obsolètes.

1. Préparation

- Se connecter sur un contrôleur de domaine avec un compte d'administration AD/GPO.
- Ouvrir Group Policy Management avec gpmc.msc.
- Identifier la GPO cible (Default Domain Policy pour les politiques de domaine ou GPO dédiée à une OU de serveurs).

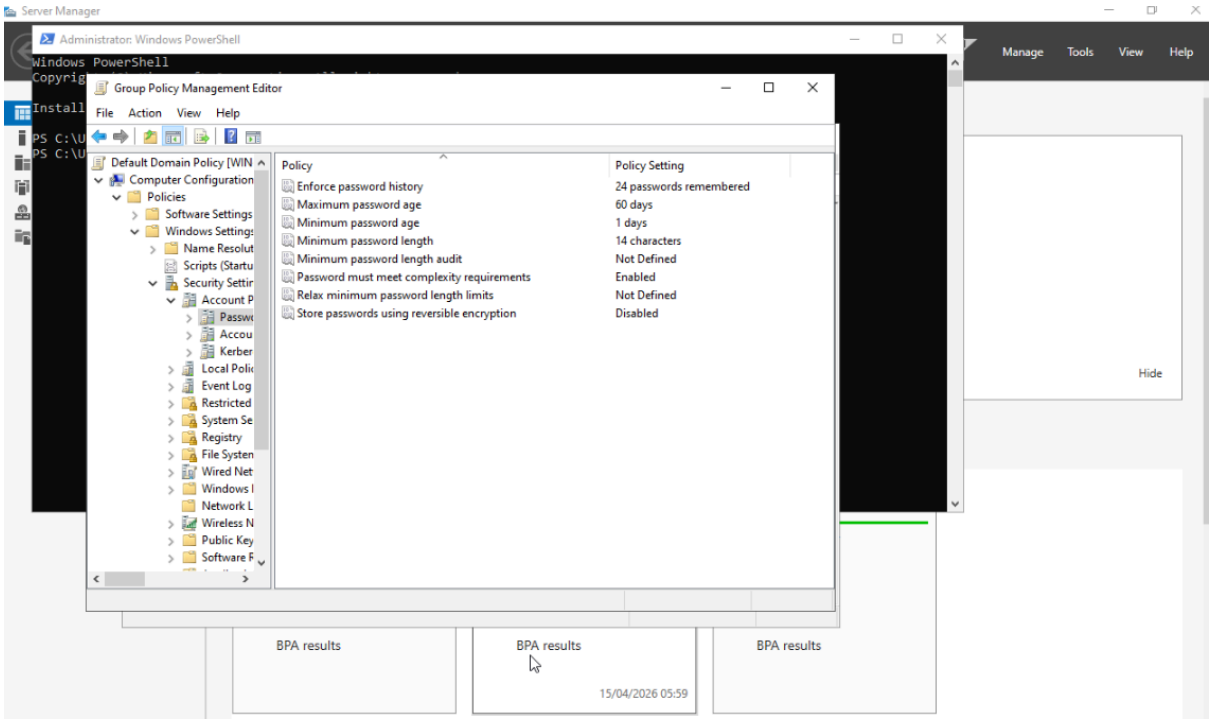
2. Politique de mots de passe

Chemin GPO : Computer Configuration → Policies → Windows Settings → Security Settings → Account Policies → Password Policy

Paramètre	Valeur TP	Justification
Enforce password history	24	Empêche la réutilisation des anciens mots de passe.
Maximum password age	60 jours	Force le renouvellement périodique.
Minimum password age	1 jour	Évite de contourner l'historique.
Minimum password length	14 caractères	Résistance renforcée au brute force.
Password must meet complexity requirements	Enabled	Impose lettres, chiffres et caractères spéciaux.

Commande d'application immédiate :

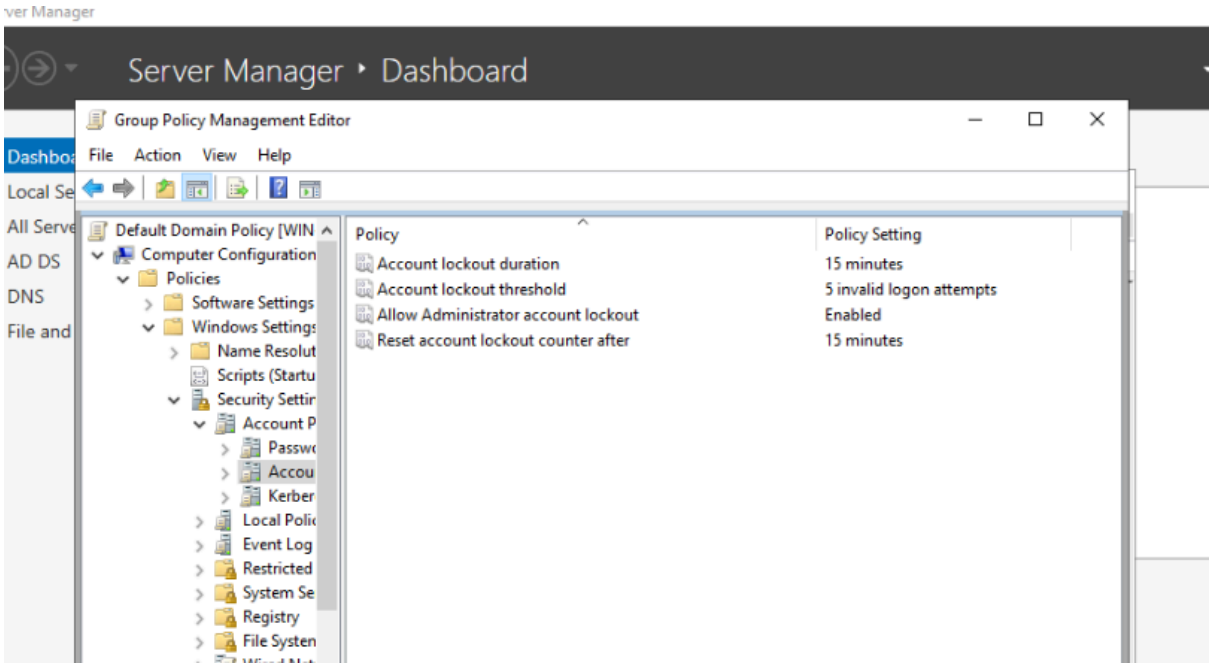
```
gpupdate /force
```



3. Verrouillage de comptes

Chemin GPO : Computer Configuration → Policies → Windows Settings → Security Settings → Account Policies → Account Lockout Policy

Paramètre	Valeur TP	Justification
Account lockout threshold	5 tentatives	Bloque le compte après plusieurs échecs.
Account lockout duration	15 minutes	Durée de blocage du compte.
Reset account lockout counter after	15 minutes	Réinitialise le compteur après une période sans échec.

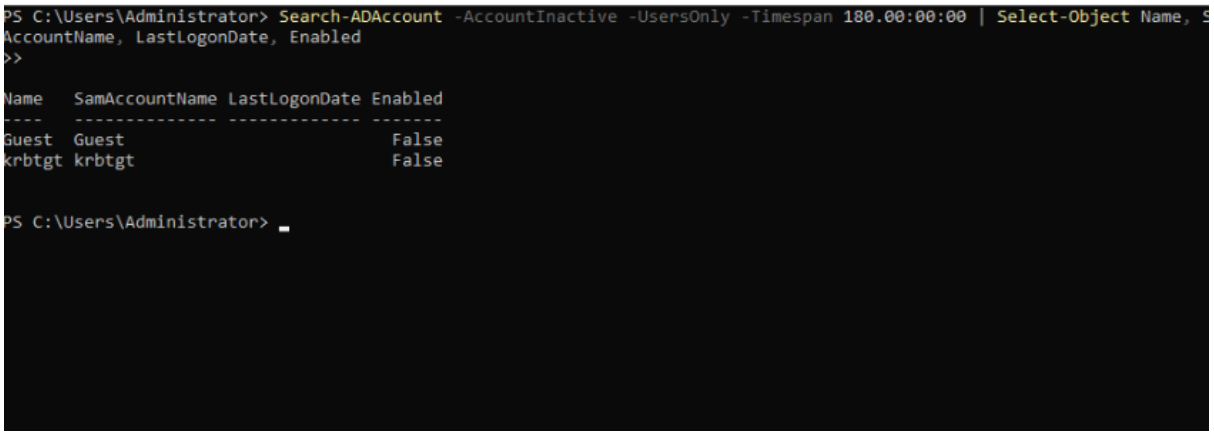


4. Audit Active Directory

4.1 Détection des comptes inactifs (>180 jours)

```
Import-Module ActiveDirectory
Search-ADAccount -AccountInactive -UsersOnly -TimeSpan 180.00:00:00 |
  Select-Object Name,SamAccountName,LastLogonDate,Enabled
```

Les comptes détectés doivent être désactivés, documentés ou supprimés après validation métier.



4.2 Vérification des groupes sensibles

Groupes à auditer en priorité : Domain Admins, Enterprise Admins, Administrators, Account Operators.

```
Get-ADGroupMember "Domain Admins" | Select-Object Name,SamAccountName,objectClass
```

Tout compte non indispensable dans ces groupes doit être retiré après validation.

```
PS C:\Users\Administrator> Get-ADGroupMember "Domain Admins" | Select-Object Name, SamAccountName, objectClass

Name          SamAccountName objectClass
----          -------------- -----------
Administrator Administrator  user


PS C:\Users\Administrator>
```

5. Désactivation de SMBv1

SMBv1 est un protocole obsolète et vulnérable (EternalBlue, WannaCry). Il doit être supprimé.

```
Get-WindowsOptionalFeature -Online -FeatureName SMB1Protocol
Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol -NoRestart
```

```
PS C:\Users\Administrator> Get-WindowsOptionalFeature -Online -FeatureName SMB1Protocol


FeatureName      : SMB1Protocol
DisplayName      : SMB 1.0/CIFS File Sharing Support
Description      : Support for the SMB 1.0/CIFS file sharing protocol, and the Computer Browser protocol.
RestartRequired  : Possible
State            : Disabled
CustomProperties :
                   ServerComponent\Description : Support for the SMB 1.0/CIFS file sharing protocol, and the Computer
                   Browser protocol.
                   ServerComponent\DisplayName : SMB 1.0/CIFS File Sharing Support
                   ServerComponent\Id : 487
                   ServerComponent\Type : Feature
                   ServerComponent\UniqueName : FS-SMB1
                   ServerComponent\Deploys\Update\Name : SMB1Protocol
```

```
PS C:\Users\Administrator> Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol -NoRestart


Path           :
Online         : True
RestartNeeded  : False
```

6. Réduction de NTLMv1 (forcer NTLMv2)

NTLMv1 est vulnérable aux attaques par relais, rejeu et cassage de hachage. La valeur 5 du registre force NTLMv2 exclusivement.

```
New-ItemProperty -Path "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa"
  -Name "LmCompatibilityLevel" -Value 5 -PropertyType DWord -Force
```

Valeur	Comportement
0	Envoie LM et NTLM — niveau minimal (déconseillé).
3	Envoie NTLMv2 uniquement, accepte LM/NTLM/NTLMv2.
5 ✓	Envoie NTLMv2 uniquement, refuse LM et NTLMv1 — niveau recommandé.

Attention : tester les applications métiers avant déploiement en production.

```
PS C:\Users\Administrator> New-ItemProperty -Path "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa" -Name "LmCompatibilityLe
el" -Value 5 -PropertyType DWord -Force


LmCompatibilityLevel : 5
PSPath               : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa
PSParentPath         : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control
PSChildName          : Lsa
PSDrive              : HKLM
PSProvider           : Microsoft.PowerShell.Core\Registry


PS C:\Users\Administrator>
```

7. Validation du Volet 1

- Exécuter gpupdate /force sur les machines cibles.

```
S C:\Users\Administrator> gpupdate /force
pdating policy...

omputer Policy update has completed successfully.
```

```
PS C:\Users\Administrator> gpresult /r

Microsoft (R) Windows (R) Operating System Group Policy Result tool v2.0
© Microsoft Corporation. All rights reserved.

Created on  15/ 04/ 2026 at 06:49:18


RSOP data for NEXATECH\Administrator on WIN-GHHIQ7G3AH1 : Logging Mode
-------------------------------------------------------------------------

OS Configuration:            Primary Domain Controller
OS Version:                  10.0.20348
Site Name:                   Default-First-Site-Name
Roaming Profile:             N/A
Local Profile:               C:\Users\Administrator
Connected over a slow link?: No


COMPUTER SETTINGS
------------------
    CN=WIN-GHHIQ7G3AH1,OU=Domain Controllers,DC=nexatech,DC=local
    Last time Group Policy was applied: 15/04/2026 at 06:47:19
    Group Policy was applied from:      WIN-GHHIQ7G3AH1.nexatech.local
    Group Policy slow link threshold:   500 kbps
    Domain Name:                        NEXATECH
    Domain Type:                        Windows 2008 or later

    Applied Group Policy Objects
    ----------------------------
        Default Domain Controllers Policy
        Default Domain Policy

    The following GPOs were not applied because they were filtered out
    -------------------------------------------------------------------
        Local Group Policy
            Filtering:  Not Applied (Empty)
```

Volet 2 — Scripting Bash d'automatisation

Objectif : créer un script audit_linux.sh qui vérifie les points de sécurité essentiels, affiche des résultats lisibles et génère un rapport horodaté.

1. Structure du script

- Variables globales : nom du rapport, date, dossier de sortie.
- Fonctions dédiées : ok(), warn(), fail(), info(), section(), score_ok/warn/fail().
- Codes de retour normalisés : 0 = OK, 1 = attention, 2 = échec.
- Résultats écrits dans un fichier texte horodaté via tee.
- Score global de conformité calculé en fin d'exécution.

2. Modules de vérification

Module	Description
check_ssh()	Vérifie l'état du service SSH, le port 22, PermitRootLogin et PubkeyAuthentication.
check_ufw()	Contrôle la présence et l'activation du pare-feu UFW, liste les règles actives.
check_file_permissions()	Vérifie les permissions de /etc/passwd (644), /etc/shadow (640), /etc/group (644), /etc/sudoers (440).
check_listening_services()	Liste tous les ports en écoute via ss -tulpn.
check_empty_passwords()	Détecte les comptes sans mot de passe valide dans /etc/shadow.
check_updates()	Vérifie la disponibilité de mises à jour système (apt ou yum).
check_ssh_dirs()	Contrôle les permissions des répertoires .ssh et authorized_keys des utilisateurs.

3. Lancement du script

```
chmod +x audit_linux.sh
./audit_linux.sh
```

Le script crée automatiquement un répertoire horodaté (ex : audit_2026-04-16_09-41-00) contenant le rapport texte.

```
root@CTEvanDel:~# chmod +x audit_linux.sh
root@CTEvanDel:~# ./audit_linux.sh
Rapport d'audit Linux - 2026-04-15T14:06:33+00:00
Hôte: CTEvanDel

===== SSH =====
[OK] Service SSH actif
[OK] Port 22 à l'écoute

===== UFW =====
[OK] UFW actif

===== /etc/passwd =====
Owner: root / Group: root / Perms: 644
[OK] /etc/passwd correctement protégé

===== Services en écoute =====
[OK] Services en écoute détectés et listés
\nRapport généré : ./audit_2026-04-15_14-06-33/rapport_audit_2026-04-15_14-06-33.txt
root@CTEvanDel:~#
```

```
root@CTEvanDel:~# ls audit_*/
audit_2026-04-15_14-06-33/:
rapport_audit_2026-04-15_14-06-33.txt

audit_2026-04-15_14-15-15/:
rapport_audit_2026-04-15_14-15-15.txt

audit_2026-04-15_14-17-34/:
rapport_audit_2026-04-15_14-17-34.txt

audit_2026-04-15_14-19-09/:
rapport_audit_2026-04-15_14-19-09.txt
root@CTEvanDel:~#
```

```
===== /etc/passwd =====
Owner: root / Group: root / Perms: 644
[OK] /etc/passwd correctement protégé

===== Services en écoute =====
Netid State  Recv-Q Send-Q Local Address:Port Peer Address:PortProcess


udp   UNCONN 0      0            0.0.0.0:68        0.0.0.0:*    users:(("dhclient",pid=179,fd=7))


tcp   LISTEN 0      128          0.0.0.0:2222      0.0.0.0:*    users:(("sshd",pid=20201,fd=6))


tcp   LISTEN 0      100        127.0.0.1:25        0.0.0.0:*    users:(("master",pid=327,fd=13))


tcp   LISTEN 0      80         127.0.0.1:3306      0.0.0.0:*    users:(("mariadbd",pid=17564,fd=32))


tcp   LISTEN 0      100            [::1]:25           [::]:*    users:(("master",pid=327,fd=14))


tcp   LISTEN 0      128             [::]:2222         [::]:*    users:(("sshd",pid=20201,fd=7))


tcp   LISTEN 0      511                *:80              *:*    users:(("apache2",pid=19533,fd=4),("apache2",pid=176
=4),("apache2",pid=17501,fd=4),("apache2",pid=17500,fd=4),("apache2",pid=17499,fd=4),("apache2",pid=17498,fd=4),("ap
",pid=17497,fd=4),("apache2",pid=17495,fd=4))
[OK] Services en écoute détectés et listés
\nRapport généré : ./audit_2026-04-15_14-19-09/rapport_audit_2026-04-15_14-19-09.txt
root@CTEvanDel:~#
```